Compliance Audit Report (Closed Gaps) and DPIA for SMS Reminder Service

Project: MediLink Health Network Enterprise Data Platform Phase: 8 - Data Security, Privacy and Compliance

8.16 Compliance Audit Report: Closed Gaps

8.16.1 Introduction

This compliance audit report identifies key data protection and security gaps relevant to MediLink Health Network and defines the corrective actions required to address them. The assessment focuses on protecting patient information across the four participating healthcare facilities in Kampala, Mukono, Mbarara, and Gulu.

The audit considers Uganda's Data Protection and Privacy Act, 2019, and Data Protection and Privacy Regulations, 2021, alongside recognised information security practices.

Audit status: The gaps below are treated as closed in the proposed control design once the stated corrective actions have been implemented and verified. They must not be represented as technically verified or legally compliant without supporting evidence.

8.16.2 Identified Gaps and Corrective Actions

Gap 1: Excessive access to patient information

Patient information could be exposed if staff have broader database permissions than their responsibilities require.

Corrective action: Implement role-based access control and the principle of least privilege. Restrict facility staff to authorised records and provide analysts with de-identified or aggregated data wherever possible.

Closure evidence: Approved access-control matrix, configured MySQL roles, and documented access review.

Status: Closed

Gap 2: Inadequate protection of sensitive identifiers

Storing national identification information without appropriate safeguards could expose patients to identity theft and unauthorised identification.

Corrective action: Restrict access to original identifiers, encrypt sensitive stored values using SHA-256 hashing where retrieval is required, and use a keyed cryptographic hash for matching where appropriate.

Closure evidence: Verified encryption configuration, key-management procedure, and tested identifier-handling process.

Status: Closed

Gap 3: Incomplete auditability

Without adequate audit trails, MediLink may be unable to determine who accessed or modified sensitive records.

Corrective action: Record authentication events, privilege changes, patient master-data corrections, ETL executions, and relevant administrative activities. Restrict access to logs and review significant events.

Closure evidence: Audit configuration, sample log records, and documented review results.

Status: Closed

Gap 4: Unclear retention and disposal controls

Keeping patient information indefinitely or deleting it prematurely may create privacy, legal, and clinical risks.

Corrective action: Apply the project retention policy requiring clinical records to be retained for 10 years and then archived for an additional 7 years, subject to validation against applicable legal and clinical requirements. Document authorised disposal procedures and exceptions.

Closure evidence: Approved retention schedule, archive records, and disposal procedure.

Status: Closed

Gap 5: Inadequate incident response arrangements

Delayed identification or escalation of a data breach could increase harm to patients and the organisation.

Corrective action: Establish an incident-response procedure covering detection, reporting, containment, investigation, recovery, and applicable notification obligations. Require immediate escalation of suspected critical incidents involving patient data.

Closure evidence: Approved incident-response plan, incident register, and documented response exercise.

Status: Closed

Gap 6: Insufficient privacy assessment for secondary uses of patient data

Using identifiable patient data for reporting, communication, or analytics without assessing the purpose and necessity may create avoidable privacy risks.

Corrective action: Document processing purposes, identify the applicable legal basis, minimise the data used, and assess privacy risks before introducing new processing activities such as SMS reminders.

Closure evidence: Approved processing documentation and completed Data Protection Impact Assessment (DPIA).

Status: Addressed by this phase's DPIA; approval and implementation verification pending.

8.16.3 Audit Conclusion

The proposed corrective actions address six priority areas: access control, identifier protection, auditability, retention, incident response, and privacy assessment.

The gaps are considered addressed at the design level, but final audit closure requires evidence that each control has been implemented, tested, and approved by the responsible personnel. Any control that fails verification must remain open until corrective action is completed.

8.17 Data Protection Impact Assessment (DPIA): SMS Reminder Service

8.17.1 Purpose of the Assessment

MediLink proposes an SMS reminder service to notify patients about upcoming appointments at participating healthcare facilities.

The service is intended to reduce missed appointments, improve continuity of care, and help facilities manage patient attendance. Because SMS messages are delivered to phone numbers that may be shared, reassigned, or accessible to other people, the service presents privacy risks that must be assessed before deployment.

This DPIA evaluates the proposed processing activity, identifies potential harms, and specifies measures to reduce those risks.

8.17.2 Description of the Processing Activity

The proposed service will use appointment information from MediLink to identify patients who should receive reminders. An authorised application will retrieve the minimum necessary contact and appointment information, generate an approved message, and submit it to an SMS gateway.

The gateway will transmit the message to the patient's registered phone number. Delivery status may be returned to MediLink for operational monitoring.

The service should process only the information necessary to deliver the reminder. It should not include diagnoses, clinical histories, national identification numbers, or other unnecessary sensitive information in SMS messages.

8.17.3 Personal Data Involved

The service may process:

- Patient name or another minimal identifier, if necessary.
- Registered phone number.
- Appointment date and time.
- Facility name or approved facility contact details.
- Message status, delivery timestamp, and a reference to the appointment.

Clinical details should not be included in the message unless a separate, justified assessment establishes that they are necessary and appropriate.

8.17.4 Purpose and Lawful Basis

The purpose is to remind patients of scheduled appointments and improve healthcare service delivery.

Before the service becomes operational, MediLink must document the applicable lawful basis for processing the phone number and appointment information under Uganda's data protection framework. The organisation must also assess any consent or notification requirements that apply to the specific communication.

The service must not assume that a patient's provision of a phone number automatically authorises every type of SMS communication. Patients should receive clear information about reminder messages, and any applicable objection or opt-out mechanism should be supported.

8.17.5 Privacy Risks

Risk 1: Disclosure to the wrong recipient

A phone number may be entered incorrectly, reassigned to another person, or shared with family members. A reminder could therefore reveal that someone is receiving healthcare services.

Mitigation: Validate phone numbers, allow patients to update contact details, and use neutral message wording that avoids revealing diagnoses or sensitive appointment details.

Risk 2: Exposure through message content

A message containing a diagnosis, treatment description, or detailed clinical information could expose sensitive information through a lock-screen notification or shared phone.

Mitigation: Use minimal, neutral wording. Do not include diagnoses, national identification numbers, or clinical histories.

Risk 3: Unauthorised access by the SMS provider

The external gateway may process phone numbers and message content, creating risks involving third-party access, retention, or onward disclosure.

Mitigation: Assess the provider's security and privacy practices, document the provider's role and obligations, restrict data sharing, and assess any applicable cross-border transfer requirements before selecting the provider.

Risk 4: Unauthorised access to reminder records

A compromised account or insecure application could expose phone numbers and appointment schedules.

Mitigation: Restrict access using role-based permissions, encrypt connections to the gateway, protect credentials, and log authorised administrative actions.

Risk 5: Excessive retention

Keeping message histories indefinitely could expose patient contact and appointment information unnecessarily.

Mitigation: Define and approve a retention period for reminder records based on operational, legal, and audit requirements. Delete or de-identify information when retention is no longer justified.

Risk 6: Repeated or incorrect reminders

Data errors or failed synchronisation could cause duplicate messages or reminders sent for cancelled appointments.

Mitigation: Validate appointment status before sending, use unique reminder identifiers to prevent duplicates, and record delivery outcomes and processing errors.

8.17.6 Necessity and Proportionality

SMS reminders are a relatively simple way to notify patients who have access to mobile phones. However, the service should process only the minimum information required to achieve its purpose.

MediLink should not disclose clinical information merely to make a reminder more descriptive. A neutral message can provide the appointment date, time, and a suitable facility contact without disclosing why the patient is attending.

The service should also provide a reasonable way for patients to correct their contact details and communicate applicable preferences concerning reminders.

8.17.7 Proposed SMS Message

A suitable initial message is:

MediLink reminder: You have an appointment at [FacilityName on [Date] at [Time]. For assistance, contact [FacilityContact]. If you received this message in error, please contact the facility.

The message deliberately avoids diagnoses and treatment details. MediLink should confirm the recipient's contact information and review the wording before sending reminders. Where appropriate, the message may also direct recipients to a secure channel for further information.

8.17.8 Risk Evaluation and Approval Conditions

The principal risks are accidental disclosure to an unintended recipient, third-party processing by the SMS provider, and unauthorised access to contact and appointment information.

These risks can be reduced through neutral message content, minimal data sharing, access controls, encryption, retention limits, and provider assessment. However, they cannot be considered eliminated.

Before deployment, MediLink should:

1. Approve and document the lawful basis for the processing.
2. Assess the SMS provider's security, confidentiality, retention, and data-transfer arrangements.
3. Test the reminder process using non-production or test records.
4. Verify that cancelled appointments do not generate reminders and that duplicate messages are prevented.
5. Confirm access restrictions, audit logging, and secure credential management.
6. Establish a process for correcting phone numbers and handling applicable patient preferences.
7. Approve a retention schedule for reminder and delivery records.

8. Obtain documented approval from the responsible data protection and service owners.

If significant residual privacy risks remain after these measures, MediLink should not launch the service until the risks have been reviewed and the necessary further measures or regulatory consultation have been completed.

8.17.9 DPIA Conclusion

The proposed SMS reminder service can support MediLink's healthcare operations, provided that the service is designed to minimise personal data processing and prevent unnecessary disclosure.

The principal safeguards are neutral message content, accurate contact details, restricted system access, secure communication with the SMS provider, controlled retention, and a documented lawful basis for processing.

DPIA status: Assessment drafted; implementation and formal approval pending. The service should proceed only after the responsible personnel have reviewed the identified risks, verified the safeguards, and documented their approval.